Diseño de una arquitectura cloud segura para un e-commerce

Objetivo general

Diseñar una **arquitectura de aplicación en la nube basada en microservicios** para una empresa de comercio electrónico, integrando principios de criptografía, seguridad, protección de datos, comunicación segura, gestión de riesgos, desarrollo ágil y DevSecOps.

El objetivo principal no es desarrollar una aplicación completa, sino justificar cómo debe diseñarse y protegerse una solución moderna desde su arquitectura.

Contexto

ReMarket es una empresa internacional de comercio electrónico que vende productos propios mediante una plataforma web.

Durante campañas especiales, promociones y temporadas altas, el sistema puede recibir grandes cantidades de solicitudes simultáneas.

La empresa necesita garantizar:

- Disponibilidad del servicio
- Escalabilidad
- Integridad de las transacciones
- Protección de datos personales
- Protección de información relacionada con pagos
- Seguridad de las comunicaciones
- Recuperación ante fallos
- Trazabilidad de las operaciones.
-

ReMarket utiliza además servicios externos para:

- Procesamiento de pagos
- Envío y seguimiento de pedidos
- Notificaciones por correo o SMS.

La empresa ha decidido migrar su plataforma hacia una arquitectura basada en microservicios desplegada en la nube.

El equipo de seguridad ha solicitado que la solución sea diseñada bajo principios de Security by Design, de manera que la criptografía y los controles de seguridad se incorporen desde la arquitectura y no como elementos añadidos posteriormente.

Arquitectura general del sistema

Diseña una arquitectura distribuida basada en microservicios.

Como mínimo deberán existir los siguientes componentes:

- Frontend web.
- API Gateway o punto de entrada.
- Servicio de autenticación y usuarios.
- Servicio de catálogo.
- Servicio de pedidos.
- Servicio de inventario.
- Servicio de pagos.
- Servicio de notificaciones.
- Base de datos transaccional.
- Base de datos o almacenamiento destinado al catálogo.
- Caché.
- Cola o bus de eventos.
- Servicio externo de pagos.
- Servicio externo de paquetería.

Puedes agregar componentes adicionales cuando estén debidamente justificados.
La arquitectura puede diseñarse utilizando AWS, Azure, Google Cloud o una arquitectura cloud genérica.

Entregable

Realiza un diagrama donde puedan identificarse claramente:

- Usuarios
- Servicios
- Microservicios
- Bases de datos
- Comunicaciones
- Servicios externos
- Zonas de confianza
- Componentes de seguridad.

No es necesario configurar ni desplegar físicamente la infraestructura.

Clasificación de información

Antes de seleccionar los mecanismos criptográficos, identifica qué información maneja el sistema.

Como mínimo analiza:

- credenciales;
- datos personales;
- direcciones;
- información de pedidos;
- inventario;
- información relacionada con pagos;
- tokens de sesión;
- registros de auditoría;
- claves criptográficas.

Clasifica cada tipo de información de acuerdo con su sensibilidad.

Para cada elemento indica:

1. dónde se genera;
2. dónde se almacena;
3. por qué servicios circula;
4. quién debería poder acceder;
5. qué ocurriría si se compromete su confidencialidad;
6. qué ocurriría si se modifica;
7. qué ocurriría si deja de estar disponible.

Criptografía aplicada al sistema

Esta es la sección principal del proyecto.

Para cada decisión deberán explicar qué propiedad de seguridad buscan proteger y por qué seleccionaron ese mecanismo.

Protección de la página web

Explica cómo protegerías la comunicación entre:

Usuario y la plataforma ReMarket.

Debes indicar:

- protocolo utilizado
- función de TLS
- certificados digitales
- autenticación del servidor
- confidencialidad
- integridad.

No basta con escribir:

“Se utiliza HTTPS”.

Debes explicar qué problema resuelve HTTPS/TLS.

Comunicación entre microservicios

Analiza cómo proteger las comunicaciones:

API Gateway → microservicios

y:

Microservicio → microservicio

Propón una estrategia utilizando mecanismos como:

- TLS
- mTLS
- autenticación mediante tokens
- certificados
- rotación de credenciales

Debes justificar qué comunicaciones requieren autenticación mutua.

API REST

ReMarket utiliza APIs REST.

Explica cómo protegerías una petición como:

POST /pedido

Analiza:

- confidencialidad
- integridad
- autenticación
- autorización;
- protección frente a repetición
- manejo de tokens.

Describe qué información debería viajar cifrada y qué información no debería enviarse innecesariamente.

Protección de datos almacenados

Explica cómo protegerías las bases de datos.

Analiza:

- cifrado en reposo
- cifrado de discos o almacenamiento
- cifrado de respaldos
- separación de claves y datos
- administración de secretos

Pregunta central:

¿Por qué no es suficiente proteger solamente la conexión HTTPS si la base de datos puede ser comprometida?

Contraseñas

El servicio de usuarios almacena las credenciales de los clientes.

Explica cómo deberían almacenarse las contraseñas.

Debes diferenciar entre:

- cifrado
- hash
- salt
- función de derivación de contraseña.

Explica por qué:

las contraseñas no deberían almacenarse mediante cifrado reversible

Gestión de claves criptográficas

Diseña una estrategia básica para administrar las claves utilizadas por el sistema.

Considera:

- generación
- almacenamiento
- acceso
- rotación
- revocación
- respaldo
- eliminación

Explica por qué las claves criptográficas:

no deberían almacenarse directamente dentro del código fuente de los microservicios.

Puedes proponer servicios como:

- KMS
- HSM
- Secret Manager

o mecanismos equivalentes.

Pasarela de pagos

ReMarket utiliza una pasarela externa para procesar pagos.

Diseña el flujo:

Usuario → ReMarket → Pasarela de pagos.

Debes identificar:

- qué datos recibe ReMarket
- qué datos deberían manejarse directamente por la pasarela
- qué información no debería almacenarse
- qué comunicaciones deben protegerse
- cómo verificar que una respuesta realmente proviene del proveedor de pagos.

Analiza el siguiente caso:

La pasarela envía un webhook:

POST /payment-confirmed

¿Cómo evita ReMarket que un atacante envíe una solicitud falsa indicando que un pedido fue pagado?

Propón mecanismos de verificación.

Firmas digitales e integridad

ReMarket genera facturas y comprobantes de compra.

Propón un mecanismo que permita detectar modificaciones posteriores.

Explica cómo podrían utilizarse:

- funciones hash
- firmas digitales
- certificados

Describe conceptualmente el flujo:

Documento

↓

Hash

↓

Firma

↓

Verificación

Explica también por qué:

firmar un documento no significa cifrarlo.

Comunicación asíncrona

El sistema utiliza una cola de eventos.

Por ejemplo:

Pedido creado → evento → servicio de notificaciones.

Analiza:

- autenticación del productor
- autenticación del consumidor
- protección del canal
- integridad del evento
- permisos mínimos.

Pregunta:

¿Qué podría ocurrir si un atacante pudiera publicar mensajes falsos en la cola?

Pipeline DevSecOps

Diseña un pipeline seguro para desarrollar y desplegar los microservicios.

El flujo puede ser:

Desarrollador

↓

Repositorio Git

↓

Build

↓

Pruebas

↓

Análisis de seguridad

↓

Creación de imagen

↓

Despliegue

Como mínimo incorpora:

- revisión de código
- análisis estático
- análisis de dependencias
- detección de secretos
- análisis de imágenes de contenedores
- pruebas automatizadas
- control de acceso
- manejo seguro de secretos
- aprobación antes de producción.

Explica en qué punto del pipeline colocarías cada control.

Seguridad de contenedores y microservicios

Propón controles para reducir el impacto de la vulneración de un microservicio.

Considera:

- mínimo privilegio
- segmentación
- aislamiento
- actualización de imágenes
- cuentas de servicio

- secretos
- permisos de red.

Responde:

Si el microservicio de catálogo es comprometido:

¿por qué no debería poder consultar directamente la base de datos de usuarios o pagos?

Evaluación de riesgos

Selecciona al menos **tres riesgos relevantes** de la arquitectura propuesta.

Como mínimo incluye uno relacionado con cada categoría:

- credenciales
- comunicaciones
- almacenamiento
- disponibilidad
- cadena de suministro o pipeline.

Puedes agregar riesgos relacionados con:

- APIs
- microservicios
- terceros
- pagos
- configuraciones cloud.

Para cada riesgo indica:

Riesgo	Activo	Amenaza	Vulnerabilidad	Impacto	Probabilidad	Nivel

Utiliza:

- Alto = 3
- Medio = 2
- Bajo = 1

Calcula:

Nivel de riesgo = Impacto × Probabilidad

Clasificación:

- 6–9: Alto.
- 3–4: Medio.

- 1–2: Bajo.

Después selecciona los riesgos más importantes y establece su tratamiento.

Para cada riesgo indica:

- control preventivo
- control detectivo
- control correctivo

Cuando sea apropiado, clasifica también el tratamiento como:

- mitigación
- evitación
- transferencia
- aceptación

Relaciona cada control directamente con un riesgo identificado.

Disponibilidad y continuidad

La aplicación deberá permanecer disponible incluso durante periodos de alta demanda.

Explica cómo incorporarías:

- balanceo de carga
- autoescalado
- redundancia
- múltiples zonas de disponibilidad
- respaldo
- replicación
- recuperación ante fallos.

Selecciona tres servicios críticos y define para cada uno:

- RTO
- RPO.

Justifica los valores seleccionados.

Uso de IA como atacante y evaluador de seguridad

ReMarket desea incorporar herramientas de inteligencia artificial para apoyar las actividades de ciberseguridad.

Analiza cómo podría utilizarse una IA desde dos perspectivas diferentes:

IA como atacante

Supón que un atacante utiliza herramientas de IA para identificar debilidades en la arquitectura propuesta.

Selecciona tres posibles escenarios de ataque en los que la IA podría facilitar o acelerar actividades como:

- generación de mensajes de phishing dirigidos
- descubrimiento de errores de configuración
- identificación de APIs expuestas
- generación de entradas maliciosas
- análisis de respuestas de la aplicación
- búsqueda de secretos o credenciales filtradas
- automatización del reconocimiento del sistema.

Para cada escenario explica:

1. Qué activo estaría intentando comprometer.
2. Qué vulnerabilidad o debilidad aprovecharía.
3. Qué impacto podría producir.
4. Qué controles de seguridad de tu arquitectura reducirían el riesgo.
5. Qué evidencia permitiría detectar el ataque.

No es necesario desarrollar código de ataque ni ejecutar técnicas ofensivas reales.

IA como evaluador de seguridad

Ahora utiliza una herramienta de IA como si fuera parte del equipo de seguridad de ReMarket.

Proporciona a la IA una descripción resumida de tu arquitectura y solicita que identifique posibles riesgos, errores de diseño o controles faltantes.

Selecciona al menos tres observaciones realizadas por la IA y evalúalas críticamente.

Para cada observación responde:

1. ¿La recomendación es técnicamente correcta?
2. ¿Aplica realmente a la arquitectura propuesta?
3. ¿Qué riesgo intenta reducir?
4. ¿La aceptarías, modificarías o rechazarías?
5. ¿Qué evidencia técnica utilizarías para justificar tu decisión?

Reflexión final

Responde:

¿Por qué una organización no debería implementar automáticamente todas las recomendaciones generadas por una IA en materia de ciberseguridad?

Relaciona tu respuesta con:

- contexto
- falsos positivos
- configuración real del sistema
- impacto operativo
- gestión de riesgos
- responsabilidad humana.

Evidencia requerida

Incluye en el informe:

- el prompt utilizado;
- un fragmento relevante de la respuesta de la IA
- tu análisis crítico
- la decisión final del equipo.

Entregables

El equipo deberá entregar:

1. Diagrama de arquitectura cloud.
2. Documento técnico de máximo 8–10 páginas.
3. Matriz de riesgos.
4. Diseño del pipeline DevSecOps.
5. Análisis del uso de la IA

No se requiere programar el sistema completo ni desplegar infraestructura real.

El examen se podrá realizar en equipos de a lo más 3 personas. Recomiendo aplicar un enfoque agíl para el desarrollo y que usen a la IA como Proyect Owner y Scrum master para que pueda guiarlos durante la planificación y desarrollo de todo el examen.

Criterio principal

No se evaluará únicamente si el alumnado menciona tecnologías.

Se evaluará principalmente si comprende:

- **qué se protege**
- **contra qué amenaza se protege**
- **qué propiedad criptográfica o control de seguridad se necesita**
- **por qué la solución propuesta es adecuada.**